Part 3 Brief · Hardening

mcp-ops-server · 18 Oct 2026 · PR #4 · Status: 112 tests, security review clean, awaiting CI and Codex review

WHAT WAS BUILT

- **Bearer-token auth.** No token or a wrong one gets HTTP 401. Tokens are stored only as SHA-256 hashes, and the server refuses to start without a tokens file (fails closed).
- **Scopes and patient binding, checked in server code.** Each tool needs its scope (`read:schedule`, `write:schedule`, `read:referrals`). A token bound to one patient can only book, cancel or read referrals for that patient.
- **Limits:** a per-client rate limit, a 64 KiB request cap (SDK default: 4 MiB), a time limit on every database call, and 100 sessions with a 10-minute idle timeout.
- **Simulated clinic clock** (default Mon 2 Nov 2026, 08:00): past slots are hidden and can't be booked. **Schema snapshot test:** any change to what agents see fails CI until approved.

HOW IT WORKS

Piece	Role
SDK middleware	Verifies the bearer token on every HTTP request and puts it in a context variable the tools can read.
Guard.check()	Called first in every tool: authenticated? within rate limit? has the scope? right patient? Raises an error the agent can read; nothing touches the database.
Store	Each call gets a deadline. A SQLite progress handler interrupts a slow statement and the transaction rolls back. Clinic time comes from an injected clock.

WHY IT WAS DONE THIS WAY

- **Security lives in code, not prompts.** Tools check the token themselves, so even a call that skips HTTP (as the unit tests do) is refused without one.
- **Interrupt inside SQLite, don't abandon a thread.** A thread can't be killed; a thread timeout would report "failed" while the booking still committed. Interrupting SQLite rolls it back.
- **Simulated time.** A real clock would make every synthetic slot "past" after November 2026 and break the evals. `MCP_OPS_NOW=system` switches to the real clock.

WHAT WENT WRONG OR SURPRISED ME (LOGGED IN FAILURES.MD)

- **Loose SDK defaults:** 4 MiB bodies, 10,000 sessions, 30-minute idle. Tightened, with a 413 test.
- **The obvious timeout was wrong** (see above). Caught at design time; a test proves a timed-out write never lands.
- **All 111 tests passed on the first run,** which Part 2 taught me to distrust. I removed each protection in turn (guard, patient binding, rate limit, timeout, past filter, schema): each removal fails at least one test.

VERIFY IT YOURSELF

```
python -m mcp_ops_server.auth issue --file tokens.json --client dev \
    --scope read:schedule --scope write:schedule --scope read:referrals   # prints token
MCP_OPS_TOKENS_FILE=tokens.json python -m mcp_ops_server   # 401 without the token
ruff check . && python -m pytest -q                        # 112 passed
```

INTERVIEW TALKING POINT

"Authorization is enforced inside every tool, not in the prompt and not only at the HTTP edge. A token bound to one patient can't book for another, even if the model is tricked into asking. And every protection has a test that fails when I delete it."

NEXT: PART 4, EVALS

A golden set of about 30 tasks, a step-by-step (trajectory) grader, a replay agent that needs no LLM, and a report. **Your action:** paste the Codex prompt, then merge PR #4 once fixes are in.